> E-BOOK GRATUITO · EMPRESAS E LGPD

# LGPD para pequenas empresas: o guia prático para se adequar

O que a lei exige de um pequeno negócio, as regras simplificadas para microempresas, um plano de adequação em 10 passos e o que fazer em caso de vazamento.

Por **Iago Silva Rezende**, perito forense digital e analista de TI · atualizado em outubro de 2026

## Neste material


01 A LGPD vale para o seu negócio?

02 Regras simplificadas para pequenos negócios

03 Os conceitos que você precisa conhecer

04 Plano de adequação em 10 passos

05 Erros comuns em pequenos negócios

06 Vazou. E agora?

07 Como posso ajudar

CAPÍTULO 01

# A LGPD vale para o seu negócio?

A Lei Geral de Proteção de Dados (Lei 13.709/2018) vale para **qualquer empresa que trata dados pessoais**, independente do tamanho. Se você guarda nome, CPF, telefone, endereço, e-mail ou foto de clientes, funcionários ou fornecedores, a lei se aplica.

"Tratar" é qualquer coisa feita com o dado: coletar, guardar, usar, compartilhar, mandar por WhatsApp, colocar em planilha ou apagar.

> **Importante**
>
> Este material é informativo e não substitui a orientação de um advogado. Ele foca nas medidas práticas e técnicas do dia a dia.

CAPÍTULO 02

# Regras simplificadas para pequenos negócios

A Autoridade Nacional de Proteção de Dados (ANPD) criou regras mais leves para os **agentes de tratamento de pequeno porte**, como microempresas, empresas de pequeno porte e startups (Resolução CD/ANPD nº 2/2022). Entre os pontos:

- Não são obrigados a indicar um encarregado de dados (DPO), mas precisam manter **um canal de contato** para os titulares.
- Podem manter o registro das atividades de tratamento de forma simplificada.
- Têm prazos maiores para responder a alguns pedidos.

As regras simplificadas **não valem** para quem faz tratamento de alto risco, como uso intenso de dados sensíveis (saúde, biometria) ou monitoramento em larga escala. Confirme o enquadramento do seu negócio com um advogado.

CAPÍTULO 03

# Os conceitos que você precisa conhecer

| Termo | O que é |
|---|---|
| Dado pessoal | Qualquer informação que identifica uma pessoa: nome, CPF, telefone, e-mail, placa do carro. |
| Dado sensível | Saúde, biometria, religião, origem racial, opinião política, vida sexual. Exige cuidado redobrado. |
| Titular | A pessoa dona do dado: seu cliente, funcionário ou fornecedor. |
| Controlador | Quem decide o que fazer com o dado. Normalmente, a sua empresa. |
| Operador | Quem trata o dado em nome da empresa: contador, sistema de gestão, empresa de marketing. |
| Base legal | O motivo permitido pela lei para usar o dado: execução de contrato, obrigação legal, consentimento, legítimo interesse, entre outros. |

CAPÍTULO 04

# Plano de adequação em 10 passos

1. **Mapeie os dados**: liste quais dados você coleta, de quem, para quê, onde ficam (planilha, sistema, WhatsApp, papel) e quem tem acesso.
2. **Defina a base legal** de cada uso. Nota fiscal é obrigação legal; entrega é execução de contrato; marketing geralmente pede consentimento.
3. **Colete só o necessário**. Se não precisa do CPF para aquele serviço, não peça.
4. **Restrinja o acesso**: cada funcionário com o seu próprio login e só o acesso de que precisa.
5. **Proteja as contas**: senhas fortes, verificação em duas etapas e bloqueio de tela nos computadores e celulares da empresa.
6. **Faça backup** automático e teste a restauração.
7. **Revise os fornecedores**: contador, sistema, hospedagem do site. Veja se o contrato fala de proteção de dados.
8. **Publique uma política de privacidade** no site, em linguagem simples, com o seu canal de contato.
9. **Prepare-se para os pedidos dos titulares**: acesso, correção, exclusão e informação sobre compartilhamento.
10. **Treine a equipe**: não mandar lista de clientes por WhatsApp pessoal, não deixar documentos expostos, desconfiar de e-mails falsos.

CAPÍTULO 05

# Erros comuns em pequenos negócios

- Lista de clientes em planilha compartilhada com "qualquer pessoa com o link".
- Fotos de documentos de clientes guardadas no celular pessoal do funcionário.
- Mesma senha para todos no sistema da empresa.
- Ex-funcionários que continuam com acesso ao e-mail ou ao sistema.
- Envio de propaganda para quem nunca autorizou.
- Computador sem backup e sem antivírus, vulnerável a ransomware.

CAPÍTULO 06

# Vazou. E agora?

1. **Contenha**: troque senhas, desconecte o computador afetado da rede e remova acessos suspeitos.
2. **Preserve as evidências**: não formate nada antes de entender o que aconteceu. Os registros mostram o que vazou e como.
3. **Avalie o risco**: quais dados, de quantas pessoas e o que pode acontecer com elas.
4. **Comunique**: se o incidente puder causar risco ou dano relevante aos titulares, a empresa deve comunicar a ANPD e os titulares. O regulamento da ANPD (Resolução CD/ANPD nº 15/2024) fixa prazo de 3 dias úteis, com regras próprias para agentes de pequeno porte.
5. **Documente tudo** o que foi feito, com datas.

As sanções da lei vão de advertência a multa de até 2% do faturamento, limitada a R$ 50 milhões por infração. Para o pequeno negócio, porém, o maior dano costuma ser a perda de confiança dos clientes.

CAPÍTULO 07

## Como posso ajudar

- Diagnóstico técnico: onde estão os dados, quem acessa e quais as falhas mais graves.
- Configuração de contas, senhas, duas etapas, backup e antivírus.
- Resposta a incidentes com preservação de evidências e laudo técnico.
- Site com política de privacidade e formulários seguros.

### Precisa de ajuda com um caso real?

Eu atendo Embu das Artes, Taboão da Serra, Itapecerica, Cotia, São Paulo e também de forma remota. A conversa inicial é sem compromisso e com sigilo.

**WhatsApp (11) 95947-3491 · rezendecyber.com.br**